MSM ACADEMY

SECTION 7

Documented information and the ISMS toolkits



7.1 What must be documented
7.2 Designing the documentation architecture
7.3 The two MSM toolkit options
7.4 Tailoring a toolkit
7.5 Controlling documented information

MSM ACADEMY

SECTION 7 · LESSON 7.1

What must be documented

Required, and chosen

7.1

LESSON 7.1

Two sources of documented information

Clause 7.5.1

a) What ISO/IEC 27001 itself requires

b) What the organization decides it needs for the ISMS to be effective

- The extent differs with size, activities, complexity and competence

LESSON 7.1

Required by Clauses 4–10

Clause	Documented information
4.3 · 5.2	Scope of the ISMS · information security policy
6.1.2 · 6.1.3	Risk assessment process · risk treatment process · Statement of Applicability · treatment plan
6.2 · 7.2	Information security objectives · evidence of competence
8.1 · 8.2 · 8.3	Evidence that processes ran as planned · risk assessment results · risk treatment results
9.1 · 9.2 · 9.3	Monitoring and measurement results · audit programme and results · management review results
10.2	Nature of nonconformities, actions taken, and corrective action results

LESSON 7.1

When a necessary Annex A control creates a documentation need

Only if the control is in your SoA

- Some controls’ wording calls for documentation, e.g. 5.10, 5.26, 5.31, 5.37, 6.6, 8.9
- For others, documentation is simply a good way to implement or evidence the control
- There is no list of “mandatory Annex A documents”

LESSON 7.1

Everything else is a choice

7.5.1 b)

- A manual, most procedures, most forms and logs are decisions, not requirements
- Decide from risks, complexity, competence and what evidence you will need
- Treat “mandatory” labels on toolkit templates with caution

Documented information: two perspectives

Implementer's view

- Start from the required list, then add by decision
- Record why each optional document exists
- Prefer evidence over paperwork

Auditor's view

- Check the required items exist and are current
- Never raise a finding for a missing optional document alone
- Test whether processes work, documented or not

Lesson 7.1 recap

- 7.5.1: what the standard requires, plus what you decide
- Clauses 4–10 require a short list, mostly evidence of results
- Some necessary Annex A controls call for documentation; there is no mandatory Annex A list
- Everything else is a choice, sized to the organization

LESSON 7.1 · KNOWLEDGE CHECK

Check your understanding

A small company has no ISMS manual. Its auditor proposes a nonconformity for this. What is the best response?

A Accept it: a manual is required by Clause 7.5

B No requirement exists for a manual; the finding is not justified on that basis alone

C Accept it, if the company has more than 50 staff

D Write a manual before the audit closes

Check your understanding

A small company has no ISMS manual. Its auditor proposes a nonconformity for this. What is the best response?

A. Accept it: a manual is required by Clause 7.5

B. No requirement exists for a manual; the finding is not justified on that basis alone

C. Accept it, if the company has more than 50 staff

D. Write a manual before the audit closes

Answer: B

ISO/IEC 27001 does not require a manual. A finding needs a requirement that is not fulfilled; the absence of an optional document is not one.

MSM ACADEMY

SECTION 7 · LESSON 7.2

Designing the documentation architecture

7.2

The MSM six-level model

The MSM six-level model

1	L1	Information security policy, and an optional manual
2	L2	Management system procedures for Clauses 4–10
3	L3	Operating procedures and topic-specific policies
4	L4	Work instructions for specific tasks
5	L5	Templates, forms, registers and records
6	L6	Guidelines that explain how to apply policies

LESSON 7.2

Level 1: policy and manual

Direction from the top

- The information security policy (5.2): required, approved by top management
- A manual is optional: a map of the ISMS, not a copy of the standard
- Keep both short enough that people actually read them

LESSON 7.2

Levels 2 and 3: procedures and topic policies

Management system, then operations

- L2: how the ISMS itself runs: documents, risk, objectives, competence, audit, review, nonconformity
- L3: how security work is done: incidents, change, backups, access and other operations
- L3 also holds topic-specific policies (Annex A 5.1) in one of the two toolkit options

LESSON 7.2

Levels 4 to 6: instructions, records, guidelines

Detail where it helps

- L4: step-by-step work instructions, only where a task needs them
- L5: templates and the records they become, the evidence auditors sample
- L6: guidelines that explain how to apply a policy in practice

LESSON 7.2

Proportionate and integrated

Fit the organization, not the toolkit

- Size and complexity decide volume, not the number of templates available
- Reuse what exists: HR, IT and quality documents often already cover parts
- Integrate with other management systems where they share processes

Architecture: two perspectives

Implementer's view

- Use the levels as a filing logic, not a quota
- Reuse and integrate before writing new
- Name the six levels as your model, not ISO’s

Auditor's view

- Expect a coherent structure, in any form
- Follow references between levels
- Check that lower levels support the policy

LESSON 7.2 · RECAP

Lesson 7.2 recap

- Six levels: an MSM architecture, not an ISO/IEC 27001 requirement
- L1 policy (required) and optional manual
- L2 runs the ISMS; L3 runs operations and can hold topic policies
- Proportionate, reused and integrated

LESSON 7.2 · KNOWLEDGE CHECK

Check your understanding

A consultant tells a client: “ISO/IEC 27001 requires six levels of documents.” What is wrong?

A Nothing: the standard defines six levels

B It requires four levels, not six

C The six levels are an implementation model, such as MSM’s; the standard prescribes no hierarchy

D Only Level 1 is defined by the standard

Check your understanding

A consultant tells a client: “ISO/IEC 27001 requires six levels of documents.” What is wrong?

A. Nothing: the standard defines six levels

B. It requires four levels, not six

C. **The six levels are an implementation model, such as MSM’s; the standard prescribes no hierarchy**

D. Only Level 1 is defined by the standard

Answer: C

The standard requires certain documented information but prescribes no document hierarchy. A levelled architecture is an implementation choice.

MSM ACADEMY

SECTION 7 · LESSON 7.3

The two MSM toolkit options

7.3

Same core, different policy layer

LESSON 7.3

Option 1 and Option 2 compared

Element	Option 1	Option 2
Level 1	ISMS policy + 14 topic policies	ISMS policy only
Topic policies	Short, at Level 1	14 detailed, at Level 3
Guidelines (L6)	14 topic guidelines + 1	1 guideline
Shared core	Manual, 9 L2 procedures, L3 procedures, 65 templates	Same
Totals	132 documents incl. blanks	118 documents incl. blanks

LESSON 7.3

Choosing an option

Match the organization’s culture

- Option 1: leaders want short policies they sign; detail sits in guidance
- Option 2: a leaner set with one policy and detailed topic policies beneath it
- Either way, keep only what the organization needs

LESSON 7.3

The master list (L5-TMP-001)

Column	What it shows
Document no. and level	A stable number; retired numbers are never reused
Clause / control references	Only directly relevant controls
Required by ISO/IEC 27001?	Required · when a necessary control calls for it · organization’s choice
Revision, owner, cross-reference	Control information for each document
Status / notes	For example: retired, blank template, S6 controlled replacement

LESSON 7.3

The risk documents

Controlled replacements from Section 6

- Risk procedure, register, treatment plan and SoA come from Section 6 unchanged
- Their method is owned by Section 6, not redesigned here
- The master list records them as controlled replacements

Toolkit options: two perspectives

Implementer's view

- Choose the option that fits how leaders read
- Keep the master list as the single index
- Use the status column honestly

Auditor's view

- Expect one index that matches reality
- Check retired numbers are not reused
- Sample documents against the master list

LESSON 7.3 · RECAP

Lesson 7.3 recap

- Same core; the options differ in the policy layer
- Option 1: short L1 policies plus guidelines
- Option 2: one policy, detailed L3 topic policies
- The master list indexes everything, with honest status

Check your understanding

A client chooses Option 2 and asks where the 14 guidelines are. What is the best explanation?

A Option 2’s Level 3 topic-specific policies already contain that detail

B They were left out by mistake

C Guidelines are mandatory and must be added

D Guidelines are only used for software development

Check your understanding

A client chooses Option 2 and asks where the 14 guidelines are. What is the best explanation?

- **A** **Option 2’s Level 3 topic-specific policies already contain that detail**
- **B** They were left out by mistake
- **C** Guidelines are mandatory and must be added
- **D** Guidelines are only used for software development

Answer: A

Option 2 places detailed topic-specific policies at Level 3, which carry the detail that Option 1 puts in Level 6 guidelines.

MSM ACADEMY

SECTION 7 · LESSON 7.4

Tailoring a toolkit

From template to owned document

7.4

From template to owned document

1	**Select**	Decide which documents the organization needs
2	**Tailor**	Rewrite to match how work is really done
3	**Clean**	Remove placeholders and text that does not apply
4	**Own**	Assign an owner and the right references
5	**Approve**	Review and approve under 7.5.2
6	**Communicate**	Make it available to the people who use it

LESSON 7.4

Keep, merge, remove

Fewer, better documents

- Keep: required, or genuinely needed for a risk or process
- Merge: two documents serving the same people and purpose
- Remove: no requirement, no risk, no user, and record why

LESSON 7.4

Common tailoring failures

What auditors find in template-based systems

- Placeholders and generic text left in: “[Organization’s Name]”
- Documents that describe practices nobody follows
- Wrong control references, and wording carried over from other standards

LESSON 7.4 · EXERCISE

Exercise: tailoring for a small organization

Northfield Logistics: 60 staff, no in-house software development, no personal devices allowed.

1 ISMS manual
2 Information security policy
3 BYOD policy
4 Password policy and access management policy
5 Secure development policy
6 Risk register

Decide keep, merge or remove for each, and give one reason.



Pause the video

Then compare with the model answer.

Model answer: tailoring

Keep	Information security policy (required, 5.2) · risk register (risk assessment results, 8.2)
Merge	Password and access management policies into one access policy for a small company
Remove	Manual (optional; a short scope document may do) · BYOD and secure development policies (no activity, no risk), with the reason recorded



Each decision rests on a requirement, a risk or a user, and is recorded.

Tailoring: two perspectives

Implementer's view

- Read every document you adopt
- Record keep, merge and remove decisions
- Make documents match real practice

Auditor's view

- Compare documents with practice
- Look for template residue
- Ask why a document was removed

LESSON 7.4 · RECAP

Lesson 7.4 recap

- Select, tailor, clean, own, approve, communicate
- Keep what is required or needed; merge; remove with a recorded reason
- Watch for placeholders, unfollowed documents and wrong references
- Fewer, better documents

Check your understanding

An organization adopts all 132 Option 1 documents unchanged in two weeks. What is the main risk?

A None: more documents means stronger compliance

B Option 1 is not accepted by certification bodies

C The master list will be too long to print

D Documents may not match practice or carry template errors, creating gaps and findings

Check your understanding

An organization adopts all 132 Option 1 documents unchanged in two weeks. What is the main risk?

A. None: more documents means stronger compliance

B. Option 1 is not accepted by certification bodies

C. The master list will be too long to print

D. Documents may not match practice or carry template errors, creating gaps and findings

Answer: D

Unchanged templates describe someone else’s practice. Gaps between documents and reality, and template residue, are what auditors find.

MSM ACADEMY

SECTION 7 · LESSON 7.5

Controlling documented information

7.5

Clauses 7.5.2 and 7.5.3

LESSON 7.5

Creating and updating

7.5.2

- Identification and description: title, number, date, author
- Suitable format and media: language, software, paper or electronic
- Review and approval for suitability and adequacy

LESSON 7.5

Control in practice

7.5.3

- Available and suitable where and when needed; adequately protected
- Distribution, access, retrieval, storage, version control, retention and disposal
- External documents needed for the ISMS are identified and controlled too

LESSON 7.5

Protection follows the information, not the document title

Classify by content

- Protection depends on content, classification and who needs access
- A risk register describing known weaknesses may need tight access
- An SoA is often shared in summary with customers or the certification body

LESSON 7.5

Records as evidence

The output of the work

- Records are produced by doing the work, not written for the audit
- Retention follows need, law and contract
- Keep previous versions where history is evidence, as for risk results

Control: two perspectives

Implementer's view

- Make the controlled version the easy one to find
- Classify documents by content
- Produce records as part of the work

Auditor's view

- Sample a document: current version, approved, available
- Check protection matches content
- Look for records created just before the audit

LESSON 7.5 · RECAP

Lesson 7.5 recap

- 7.5.2: identify, format, review and approve
- 7.5.3: available, protected, distributed, versioned, retained
- Protection follows the information, not the title
- Records are produced by the work

LESSON 7.5 · KNOWLEDGE CHECK

Check your understanding

A team stores the current procedure on the intranet, but staff use printed copies from two years ago. Which part of 7.5 is most at risk?

A 7.5.1 a)

B 7.5.2 c), review and approval

C 7.5.3: availability of the current version and version control at the point of use

D None: the intranet copy is current

Check your understanding

A team stores the current procedure on the intranet, but staff use printed copies from two years ago. Which part of 7.5 is most at risk?

A. 7.5.1 a)

B. 7.5.2 c), review and approval

C. **7.5.3: availability of the current version and version control at the point of use**

D. None: the intranet copy is current

Answer: C

The current version exists, but it is not what people use. 7.5.3 requires suitable documented information where it is needed, with version control.

SECTION 7 · SUMMARY

Documented information in one view

- Required by the standard, plus what you decide you need
- Organized by an architecture such as the MSM six levels
- Choose a toolkit option, then tailor: keep, merge, remove
- Control it: approve, protect by content, keep records

MSM ACADEMY

SECTION 7 COMPLETE

Next: Section 8

Auditing the ISMS

